SECURITY AWARENESS TRAINING AND EDUCATION

WyIT - 3004

PURPOSE: This policy implements a security awareness and training program. The Chief Information Officer (CIO) understands that people, not necessarily technology, are often the largest threat to the security of sensitive information within the State.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by WyIT - 3002 - Security Exception Request policy.

IV. SECURITY AWARENESS TRAINING

All agencies and affiliates identified in the scope of this policy shall:

- Schedule security awareness training as part of initial training for new users.
- Schedule security awareness training when required by information system changes and then annually thereafter.
- The CIO shall assign State employees appropriate content of security awareness training and security awareness techniques based on the enterprise training solution. The content shall:

- Include a basic understanding of the need for information security and user actions to maintain security and to respond to suspected security incidents.
- Address awareness of the need for operations security. Security awareness techniques can include, for example, displaying posters, offering supplies inscribed with security reminders, generating email advisories/notices from senior organizational officials, displaying login screen messages, and conducting information security awareness events.

V. SECURITY AWARENESS | INSIDER THREAT

All affiliates and agencies identified in the scope of this policy shall:

- Include security awareness training on recognizing and reporting potential indicators of insider threat.

VI. ROLE-BASED SECURITY TRAINING

All affiliates and agencies identified in the scope of this policy shall:

- Provide role-based security training to personnel with assigned security roles and responsibilities:
  - Before authorizing access to the information system or performing assigned duties.
  - When required by the information system changes and annually thereafter.
- Designate personnel to receive initial and ongoing training in the employment and operation of environmental controls to include, for example, fire suppression and detection devices/systems, sprinkler systems, handheld fire extinguishers, fixed fire hoses, smoke detectors, temperature/humidity, HVAC, and power within the facility.

VII. PHYSICAL SECURITY CONTROLS

All affiliates and agencies identified in the scope of this policy shall:

- Provide initial and ongoing training in the employment and operation of physical security controls; physical security controls include, for example, physical access control devices, physical intrusion alarms, monitoring/surveillance equipment, and security guards (deployment and operating procedures).

- Identify personnel with specific roles and responsibilities associated with physical security controls requiring specialized training.

VIII. PRACTICAL EXERCISES/CAMPAIGNS

All affiliates and agencies identified in the scope of this policy shall:

- Provide practical exercises in security training that reinforce training objectives; practical exercises may include, for example, security training for software developers that includes simulated cyber-attacks exploiting common software vulnerabilities (e.g., buffer overflows), or spear/whale phishing attacks targeted at senior leaders/executives. These types of practical exercises help developers better understand the effects of such vulnerabilities and appreciate the need for security coding standards and processes.

IX. SUSPICIOUS COMMUNICATIONS AND ANOMALOUS SYSTEM BEHAVIOR

All affiliates and agencies identified in the scope of this policy shall:

- Provide training to its specified staff on how to recognize suspicious communications and anomalous behavior in organizational information systems.

X. SECURITY TRAINING RECORDS

All affiliates and agencies identified in the scope of this policy shall:

- Designate personnel to document and monitor individual information system security training activities including basic security awareness training and specific information system security training.
- Retain individual training records in accordance with compliance requirements and/or State archive requirements.

REFERENCES: This policy has no supporting references to websites, other policies, federal or state statutes.

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
July 2024	ETS Governance, Risk and Compliance	Public Comment Period	07/26/2024 - 08/09/2024	August 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**